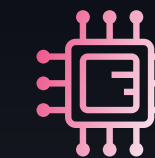


ANÁLISIS Y PLANIFICACIÓN DEL PENTEST





AegisCipher
Ethicalhacking

OBJETIVO DEL PENTEST

Evaluación de seguridad

01

VULNERABILIDADES DE CONTROL DE ACCESO

En la aplicación web relacionado al incidente reportado podríamos evaluar si es una falla de autorización o un posible IDOR.

02

SEGURIDAD DE AUTENTICACIÓN Y SESIONES

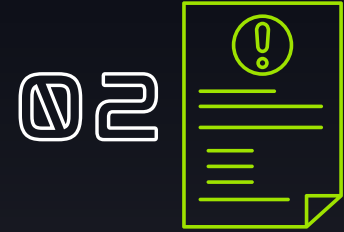
Identificar posibles fallas en la gestión de roles y permisos, debido al híbrido de usuarios (clientes y personal) en un mismo sistema puede derivar accesos no autorizados o fuga de información.

03

NIVEL DE EXPOSICIÓN DE INFORMACIÓN

Tal como lo mencionamos en el punto anterior, es importante revisar la información sensible almacenada (datos personales, pedidos o historial) antes de un posible ataque.





02

ALCANCE

Si se evaluará

- PANEL ADMINISTRATIVO DE PERSONAL
- APLICACIÓN WEB DE AM Y SUS FUNCIONALIDADES: LOGIN, REGISTRO, CARRITO, CUENTA, ETC.
- MECANISMOS DE AUTENTICACIÓN Y AUTORIZACIÓN.
- BASE DE DATOS PARA VALIDAR COMO INTERACTUA LA APLICACIÓN CON ELLA.

Fuera del alcance

- REDES SOCIALES.
- CORREOS, EQUIPOS, SERVIDOR.
- PROVEEDORES.
- CUALQUIER SISTEMA QUE NO SEA LO QUE SE AUTORIZO.



03

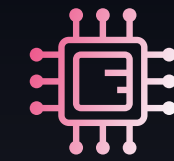
AUTORIZACIÓN Y CONDICIONES

Permisos requeridos

- AUTORIZACIÓN FORMAL POR ESCRITO.
- DEFINICION CONCISA DEL ALCANCE FIRMADA POR AMBAS PARTES.
- VENTANAS DE TIEMPO AUTORIZADAS PARA PRUEBAS (HORARIOS DE MENOR ACTIVIDAD).
- RESULTADOS QUE DETERMINEN SI PODRIA DESCUBRIR UN ATACANTE DEPENDIENDO DE LA INFORMACIÓN.

Condiciones acordadas

- SOLO APLICACIÓN WEB AUTORIZADA.
- NO SE ATACA INFRAESTRUCTURA FUERA DEL ALCANCE.
- NO DEBEMOS AFECTAR INFORMACION REAL DE CLIENTES.
- COMUNICACION CONSTANTE CON EL EQUIPO DE AM.
- EVITAR ACCIONES QUE INTERRUMPAN EL SERVICIO. Ejm (DoS)



AegisCipher
Ethicalhacking



04



TIPO DE PENTEST

Escenario



www.auroramarket.com



05



PLANIFICACIÓN

Elementos clave

Evaluar fallas de control de acceso, autenticación/sesiones y exposición de información sensible en la aplicación web de Aurora Market.

La aplicación web de Aurora Market (login, registro, carrito, cuenta, panel administrativo) y sus mecanismos de autenticación y base de datos; quedan fuera redes sociales, correos, equipos, servidores y proveedores.

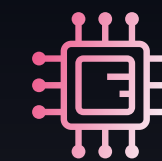
Autorización formal por escrito, alcance definido y firmado, pruebas en horarios de menor actividad, sin afectar información real de clientes ni interrumpir el servicio, manteniendo comunicación constante con Aurora Market.

Metodología OWASP Testing Guide o Penetration Testing Execution Standard.

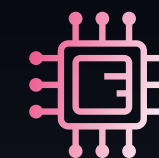
Revisar la app públicamente (rutas visibles, tipos de usuario, funcionalidades expuestas), sin tocar nada fuera de alcance.

Navegador, proxy interceptor (ej. Burp Suite), cuenta de prueba en la plataforma, entorno de pruebas controlado.

Con base en la información que nos compartió el equipo de Aurora Market, identificamos que los horarios de mayor actividad son de 12pm a 3pm y de 5pm a 7pm, coincidiendo con horas de comida y salida de trabajo, donde más usuarios navegan y compran en la plataforma. Por eso, definimos como ventana ideal para ejecutar las pruebas técnicas el horario de 11:00 pm a 6:00 am, ya que es cuando el tráfico de clientes es considerablemente menor, reduciendo el riesgo de afectar la experiencia de usuarios reales durante la evaluación.



AegisCipher
Ethicalhacking



FASES DEL PENTEST

Como lo aplicamos

- Reconocimiento: mapear la aplicación — páginas, funcionalidades, roles de usuario (cliente vs. administrador), formularios, endpoints visibles.
- Análisis de vulnerabilidades: buscar fallas de control de acceso (IDOR), inyección, gestión de sesiones débil, exposición de datos sensibles — enfocado en el incidente reportado.
- Explotación: Validar de forma controlada si es posible acceder a información de otro usuario sin autorización (replicar el incidente reportado de forma ética y segura).
- Post-explotación: Determinar el impacto real — ¿cuántos datos podrían exponerse?, ¿se podría escalar a la cuenta admin?, ¿cuántos usuarios están en riesgo?
- Informe: Documentar hallazgos, evidencias, nivel de riesgo (crítico/alto/medio/bajo) y recomendaciones de remediación para el equipo de desarrollo.

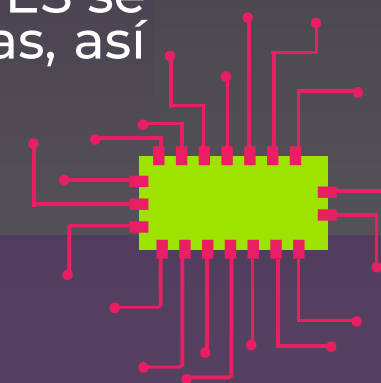


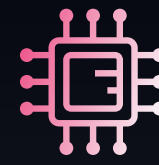
INVESTIGACIÓN

Elegí la metodología OWASP Testing Guide porque está diseñada específicamente para evaluar aplicaciones web, que es justo el caso de Aurora Market. Como el incidente reportado apunta a una posible falla de control de acceso, y sabemos que existen distintos tipos de usuario en la plataforma, OWASP me da un marco claro para revisar puntos como autenticación, gestión de sesiones y control de acceso, que son exactamente las áreas que definimos como objetivos del pentest."

También consideré usar PTES porque no solo cubre las pruebas técnicas, sino todo el proceso completo del pentest: desde la planificación y el reconocimiento hasta la explotación y el informe final. Como nosotros ya estructuramos el trabajo en fases (reconocimiento, análisis, explotación, post-explotación e informe), PTES encaja muy bien porque nos da una guía ordenada para cada una de esas etapas.

Al final me decidí por OWASP porque se enfoca más en el qué probar dentro de la aplicación web, mientras que PTES se enfoca más en el cómo organizar todo el proceso. Para este caso, priorizo encontrar las vulnerabilidades específicas, así que OWASP fue mi elección principal.





AegisCipher
Ethicalhacking

GRACIAS



auroramarket@gmail.com



www.auroramarket.com